

Chapitre 10

Étude de cas — criminalité financière et fraude

Feuille d'exercices

Jaouad Madkour

Faculté d'Économie et de Gestion de Tanger
Exercices et corrigés · Risque opérationnel et résilience

1 Exercices du chapitre

Exercice 1 — La criminalité financière : un périmètre large, selon la FCA et selon Bâle

- (a) Le manuel de la Financial Conduct Authority (FCA) définit la criminalité financière comme « toute conduite criminelle liée à l'argent ou aux marchés financiers, incluant la fraude ou la malhonnêteté, le mésusage d'information sur un marché financier, le traitement du produit d'un crime, et le financement du terrorisme », une définition qui « recouvre ainsi la fraude interne et externe et ce que l'on appelle communément le blanchiment de capitaux et le financement du terrorisme ». Énumérer les quatre composantes de cette définition. Pourquoi le cours affirme-t-il que la fraude et la LCB-FT, deux disciplines dotées chacune de son propre corpus réglementaire et de ses propres équipes spécialisées, sont néanmoins traitées ensemble dans ce chapitre, alors qu'un chapitre entier (le chapitre 9) a déjà été consacré à la seule LCB-FT ? Justifier à partir de la dernière phrase de l'encadré introductif du chapitre.
- (b) Selon Bâle, la fraude interne se subdivise en « activités non autorisées » (« violation intentionnelle de la loi ou des règles internes, sans perte financière nécessaire — partage de mots de passe, mauvaise classification de positions de trading ») et « vol et fraude » (« détournement d'actifs, extorsion, corruption »). Expliquer précisément pourquoi la première sous-catégorie précise « sans perte financière nécessaire » : quel type d'acte serait autrement exclu du périmètre de la fraude interne si seule une perte financière avérée pouvait le qualifier comme tel ? Donner, pour chacune des deux sous-catégories, un exemple qui n'est pas déjà cité par le cours mais qui en respecte la définition.
- (c) La fraude externe — « vol à main armée, fraude à la carte bancaire, fraude au virement, falsification de revenus dans une demande de prêt » — « exige des équipes spécialisées travaillant souvent avec les forces de l'ordre », avec une « sécurité physique pour les agences et distributeurs » et des « équipes dédiées à la fraude sur chèques et cartes en banque de détail ». En quoi la nature des contrôles nécessaires à la fraude externe (sécurité physique, coopération avec des tiers externes comme les forces de l'ordre) diffère-t-elle structurellement de celle des contrôles de fraude interne évoqués par ailleurs dans le chapitre (séparation des tâches, droits d'accès) ? Cette différence tient-elle à la gravité du préjudice, ou à l'identité de l'auteur de la fraude ?
- (d) Selon l'American Bankers Association, « les tentatives de fraude ont triplé en 2021 par rapport au début du confinement de mars 2020 », le télétravail massif ayant « ouvert de nouvelles brèches — hameçonnage par courriel multiplié par 6 à 7 sur la première année de la pandémie, escroqueries au virement bancaire en forte hausse ». Expliquer précisément le mécanisme par lequel le passage généralisé au télétravail a pu multiplier les tentatives de hameçonnage par courriel, plutôt que simplement les tentatives de fraude en général. En quoi cet épisode illustre-t-il que le risque de fraude, bien que « contrôlable » par nature au sens des chapitres précédents, reste sensible à des chocs exogènes qui élargissent brutalement la surface d'exposition, sans que la nature du risque lui-même n'ait changé ?

Exercice 2 — Gérer le risque de fraude : les quatre piliers et le paradoxe de la tolérance zéro

- (a) Un dispositif de gestion de la fraude interne repose sur quatre piliers : « la **sélection** (vérification des antécédents des employés et tiers, ton donné par la direction, alignement des valeurs) ; la **prévention** (séparation stricte des tâches, droits d'accès et délégations d'autorité clairement délimités) ; la **détection** (supervision d'équipe, dispositif d'alerte, rapprochements comptables) ; et les **dissuasions** (sanctions annoncées, poursuites judiciaires) ». Pour chacun des quatre piliers, identifier précisément à quel moment du cycle de vie de la fraude potentielle il intervient (avant l'entrée en relation, pendant l'exercice courant des fonctions, après l'acte, etc.). En quoi la sélection, qui porte sur les « employés et tiers » avant même leur entrée en fonction, se distingue-t-elle de la prévention, qui porte au contraire sur l'organisation courante du travail (séparation des tâches, droits d'accès) une fois la relation déjà établie — alors que les deux piliers sont, l'un comme l'autre, des mesures *ex ante* par rapport à l'acte frauduleux lui-même ?

- (b) « La quasi-totalité des établissements affichent une «tolérance zéro» envers la fraude interne dans leur appétence au risque. Cela signifie que tout auteur identifié sera sanctionné — non que le dispositif de prévention rend la fraude impossible. La détection reste donc essentielle : elle limite l’ampleur du préjudice et, en retour, dissuade — le risque d’être pris étant lui-même le premier frein à la tentation. » Reformuler précisément la distinction que fait le cours entre ce que la « tolérance zéro » garantit (une sanction systématique *a posteriori*) et ce qu’elle ne garantit pas (l’impossibilité *a priori* de la fraude). Expliquer ensuite la boucle causale à deux étapes que décrit la dernière phrase : par quel mécanisme la détection, qui n’agit *a priori* qu’après l’acte frauduleux, en vient-elle à réduire la probabilité même que cet acte soit tenté ?
- (c) Comparer la fraude externe (« vol à main armée, fraude à la carte bancaire, fraude au virement, falsification de revenus »), qui « exige des équipes spécialisées travaillant souvent avec les forces de l’ordre », à la fraude interne, gérée par les quatre piliers du (a). Le pilier de « dissuasion » (« sanctions annoncées, poursuites judiciaires ») a-t-il le même sens et la même portée pratique pour un employé de la banque que pour un fraudeur externe anonyme qui ne sera identifié, le cas échéant, qu’après enquête des forces de l’ordre ? Justifier en identifiant ce qui, dans le cas de la fraude interne, rend la dissuasion *ex ante* crédible (connaissance préalable de la politique par l’employé) d’une façon qui ne s’applique pas nécessairement à un fraudeur externe.
- (d) Le cours affirme que « la détection reste [...] essentielle » précisément parce que la prévention ne « rend [pas] la fraude impossible ». En vous appuyant sur la définition de la détection donnée au (a) — « supervision d’équipe, dispositif d’alerte, rapprochements comptables » —, expliquer pourquoi ces trois mécanismes de détection sont conçus pour repérer une fraude qui a déjà échappé aux mesures de sélection et de prévention, plutôt que pour la prévenir en amont. Un établissement qui investirait exclusivement dans la sélection et la prévention, sans consacrer de ressources à la détection, serait-il conforme à la logique des quatre piliers telle que décrite par le cours ?

Exercice 3 — Lutter contre le blanchiment : trois phases, KYC, RegTech, et le cas USAA

- (a) Le blanchiment de capitaux suit typiquement trois étapes : « le **placement** dissimule l’origine des fonds (transfert vers une entreprise-écran, fausses factures, trusts et sociétés offshore, ou le « saupoudrage » consistant à fractionner une grosse transaction en petits montants pour rester sous les seuils de déclaration). L’**empilage** combine placements et retraits selon des montants et des schémas variés, pour brouiller la piste des transactions. L’**intégration** consiste enfin à réinjecter les fonds dans l’économie légale ». Pour chacune des trois phases, indiquer précisément ce que le blanchisseur cherche à accomplir et pourquoi l’ordre (placement, puis empilage, puis intégration) est nécessairement celui-là : pourquoi l’intégration ne pourrait-elle pas précéder le placement ?
- (b) « La vérification de l’identité et de l’origine des fonds d’un client — le « know-your-customer » (KYC) — est la première étape, et la plus importante, du dispositif de LCB-FT. Les régulateurs recommandent une approche fondée sur le risque : plus le risque est élevé, plus les contrôles doivent être stricts, et inversement. » Énumérer les cinq facteurs cités par le cours qui déterminent la classification d’un client en risque faible, moyen ou élevé. Pourquoi une approche « fondée sur le risque », plutôt qu’un socle de contrôles uniformes appliqué indistinctement à tous les clients, est-elle présentée comme la pratique recommandée — quel arbitrage entre coût de la diligence raisonnable et exhaustivité des contrôles cette approche cherche-t-elle précisément à optimiser ?
- (c) « Les entreprises de « RegTech » automatisent désormais une partie de ce travail par apprentissage automatique — vérification d’identité, détection d’anomalies dans le comportement d’un client, criblage contre les listes de personnes sanctionnées ou politiquement exposées (PEP). » Le cours ajoute que « la mise en place d’un tel système exige un paramétrage soigné et un suivi rigoureux des faux positifs et des faux négatifs », faute de quoi l’établissement « s’expose au double risque de noyer ses équipes sous des alertes inutiles ou de laisser passer une activité réellement suspecte ». Expliquer précisément pourquoi un système d’alerte automatisé mal paramétré peut simultanément produire *trop* de faux positifs et laisser passer des faux négatifs, plutôt que de simplement pencher d’un côté ou de l’autre. En quoi le suivi des deux

types d'erreur constitue-t-il une « boucle de rétroaction », c'est-à-dire un processus continu plutôt qu'un réglage figé une fois pour toutes ?

- (d) En mars 2022, USAA Federal Savings Bank a été sanctionnée à hauteur de 140 millions USD par le FinCEN et l'OCC pour « défaillance délibérée » de son dispositif LCB-FT entre janvier 2016 et avril 2021 ; le régulateur a relevé un département conformité « significativement sous-effectif », comblé par des sous-traitants non qualifiés, et un nouveau système de surveillance déployé en 2021 « trop sensible », générant un arriéré d'environ 90 000 alertes et 6 900 dossiers non examinés fin 2021. Le cours précise que « le constat du régulateur portait sur la qualité du dispositif de contrôle, non sur des faits avérés de blanchiment — un dispositif de contrôle défaillant suffit à justifier une sanction ». En reliant ce cas au (c), expliquer pourquoi un système « trop sensible » — donc produisant, *a priori*, davantage de vraies alertes détectées et non moins — a pu, dans les faits, dégrader plutôt qu'améliorer la qualité du dispositif de surveillance d'USAA. Pourquoi le cours insiste-t-il sur le fait que la sanction ne repose pas sur des faits avérés de blanchiment : qu'est-ce que cela révèle sur la nature même de l'obligation réglementaire en matière de LCB-FT ?

2 Exercice cumulatif (chapitres 10, 9, 8, 7, 6)

Exercice 4 — La criminalité financière à la lumière des quatre chapitres précédents

- (a) Le chapitre 9 exige qu'une banque « développe une compréhension approfondie des risques ML/FT inhérents à sa base de clientèle, ses produits, ses canaux de distribution », qu'elle nomme « un responsable en chef de la conformité AML/CFT (chief AML/CFT officer), doté d'une autorité et d'un statut suffisants », qu'elle dispose d'« un système de surveillance adapté à sa taille, ses activités et sa complexité », et il ajoute que « l'audit interne doit évaluer périodiquement le système de surveillance informatisé pour s'assurer qu'il est utilisé effectivement par les première et deuxième lignes de défense ». Ce chapitre montre, à travers les trois phases du blanchiment, le KYC fondé sur le risque et l'automatisation RegTech, comment une banque opérationnalise concrètement ces exigences générales du chapitre 9 — puis, à travers le cas USAA, ce qui se produit quand elle échoue à le faire : un département « significativement sous-effectif », comblé par des « sous-traitants dont les qualifications n'avaient pas été vérifiées ». Montrer que le cas USAA de ce chapitre est très précisément un cas où l'exigence du chapitre 9 concernant l'audit interne comme « garant de l'effectivité » du système de surveillance a elle-même fait défaut : quel indice, dans les faits rapportés sur USAA, suggère que ni la fonction de contrôle interne ni son évaluation par l'audit n'ont su, en amont de la sanction, détecter et corriger le sous-effectif et le recours à des sous-traitants non qualifiés avant que le régulateur ne le fasse à leur place ?
- (b) Le chapitre 8 tire du cas Equifax la leçon suivante : « un événement de risque opérationnel majeur résulte rarement d'une cause unique », illustrée par cinq faiblesses interconnectées (inventaire défaillant, correctifs non appliqués, communication interne rompue, certificat expiré, communication de crise tardive). Ce chapitre rapporte, pour USAA, une conjonction tout aussi multiple de défaillances : sous-effectif, sous-traitants non qualifiés, et système de surveillance « trop sensible » générant un arriéré de 90 000 alertes. Montrer que le cas USAA est, structurellement, une nouvelle instance de la thèse du chapitre 8 sur la causalité multiple des événements de risque opérationnel majeurs, en appariant chacune des défaillances d'USAA à une défaillance de nature comparable chez Equifax (par exemple : le sous-effectif du service conformité d'USAA face à l'absence d'« inventaire exhaustif des actifs informatiques » chez Equifax — dans les deux cas, un manque de ressources ou de visibilité empêchant une action corrective en temps voulu). Par ailleurs, le chapitre 8 classe les risques de sécurité de l'information selon une matrice croisant la cause (interne/externe) et la nature de l'incident (vol/perte), tandis que ce chapitre distingue, selon Bâle, la fraude **interne** (impliquant « au moins une partie interne ») de la fraude **externe** (« perpétrée par un tiers »). Montrer que cet axe interne/externe est commun aux deux chapitres, bien qu'il s'applique à des objets différents (l'information chez le chapitre 8, l'argent et les actifs chez ce chapitre) : pourquoi un même

critère de classification (l'origine, interne ou externe, de la menace) s'avère-t-il pertinent pour des catégories de risque aussi distinctes que la sécurité de l'information et la fraude?

- (c) Le chapitre 7 constate que « la plupart des juridictions se concentrent encore sur des indicateurs rétrospectifs [...], pertinents lorsque l'environnement est stable — ce qui n'est pas le cas face à des adversaires cyber qui adaptent continuellement leurs tactiques », le patch ageing illustrant « la nécessité de développer des indicateurs prospectifs de résilience, encore peu harmonisés ». Ce chapitre exige, pour l'automatisation RegTech en LCB-FT, « un suivi rigoureux des faux positifs et des faux négatifs », faute de quoi l'établissement « ne peut ni apprendre ni améliorer son dispositif ». Montrer que ces deux exigences — l'indicateur prospectif du chapitre 7 et le suivi des faux positifs/négatifs de ce chapitre — répondent au même problème structurel sous deux formes différentes : un dispositif de détection automatisé, qu'il porte sur des cybermenaces ou sur des opérations suspectes, se dégrade silencieusement si son paramétrage n'est jamais réévalué à la lumière de ses propres résultats. En quel sens le système de surveillance « trop sensible » d'USAA, qui a généré un arriéré de 90 000 alertes non traitées, est-il un exemple concret et chiffré de ce que le chapitre 7 ne fait que nommer abstraitement comme un manque « d'indicateurs prospectifs [...] encore peu harmonisés »?
- (d) Le chapitre 6, dans sa synthèse, retient du cas de la Commonwealth Bank of Australia (CBA) « un cadre de gestion du risque opérationnel « meilleur sur le papier qu'en pratique » », et rappelle le rôle du « comité des risques du conseil d'administration [...] supervisant l'ensemble des risques de l'organisation », dans un modèle à trois lignes de défense où la deuxième ligne « définit les méthodes et exerce une surveillance indépendante ». Ce chapitre conclut sur le cas USAA en soulignant que « les amendes réglementaires lourdes ne surgissent jamais de nulle part : elles sanctionnent des années de manquements accumulés et de report des correctifs nécessaires », mais aussi que « le constat du régulateur portait sur la qualité du dispositif de contrôle, non sur des faits avérés de blanchiment ». Comparer précisément les deux cas : le rapport de l'APRA sur la CBA documentait, selon le chapitre 6, des manquements *avérés* (« blanchiment de capitaux, surfacturation de clients, pertes de données »), tandis que la sanction d'USAA, selon ce chapitre, ne repose que sur la *qualité défaillante* du dispositif de contrôle, sans blanchiment avéré. Qu'est-ce que cette différence révèle sur l'étendue du pouvoir de sanction des régulateurs en matière de risque non financier, comparée à une logique qui n'agirait qu'*a posteriori* d'un préjudice démontré? Montrer enfin que la formule « meilleur sur le papier qu'en pratique », appliquée par le chapitre 6 à la CBA, décrit tout aussi bien le programme de conformité qu'USAA prétendait maintenir « conforme aux exigences minimales du Bank Secrecy Act » avant que le régulateur n'en révèle les failles.

3 Applications en sciences économiques

Exercice 5 — L'arriéré d'alertes LCB-FT : capacité et arbitrage, chiffré

Une banque reçoit chaque mois 12 000 alertes générées par son système de surveillance des transactions. Chaque analyste conformité peut traiter 150 alertes par mois, et la banque emploie actuellement 55 analystes. Sur l'ensemble des alertes effectivement traitées, 3 % débouchent sur une déclaration de soupçon (SAR) auprès de la cellule de renseignement financier. Un analyste supplémentaire coûte 85 000 \$ par an à la banque (salaire chargé).

- (a) Calculer la capacité de traitement mensuelle actuelle de l'équipe conformité, puis l'accroissement net mensuel de l'arriéré d'alertes non traitées (alertes reçues moins alertes traitées).
- (b) En supposant que cet accroissement net reste constant, calculer la taille de l'arriéré après 12 mois, puis le nombre de mois nécessaires pour que l'arriéré atteigne 90 000 alertes non traitées — l'ordre de grandeur rapporté par le régulateur dans le cas USAA étudié par le cours.
- (c) Calculer le nombre d'analystes supplémentaires strictement nécessaires pour que la capacité de traitement mensuelle égale exactement le flux d'alertes entrant (et donc pour stopper la croissance de l'arriéré), ainsi que le coût annuel correspondant. Le comité des risques estime

que la probabilité qu'un arriéré persistant au-delà du seuil du (b) déclenche, dans les cinq ans, une sanction réglementaire de l'ordre de celle infligée à USAA (140 millions de dollars) est de 30 %. Calculer le coût réglementaire attendu (probabilité multipliée par le montant de la sanction), et le comparer au coût annuel du recrutement calculé ci-dessus. Le recrutement est-il économiquement justifié au regard de ce seul arbitrage ?

- (d) Calculer le nombre de déclarations de soupçon mensuelles produites par l'équipe actuelle (à capacité pleine, donc en traitant 8 250 alertes), puis celui qui serait produit par une équipe capable de traiter la totalité du flux mensuel de 12 000 alertes. En déduire le nombre annuel de déclarations de soupçon supplémentaires que permettrait le recrutement du (c), et le coût additionnel par déclaration de soupçon supplémentaire ainsi obtenue. Ce coût par déclaration supplémentaire vous semble-t-il un critère de décision suffisant, à lui seul, pour juger de la pertinence du recrutement — ou le calcul du (c) reste-t-il, selon vous, le critère décisif ?

Exercice 6 — Le saupoudrage sous seuil de déclaration, chiffré

Un blanchisseur professionnel doit placer 480 000 \$ de fonds d'origine illicite pour le compte d'un client, en les fractionnant en dépôts de 9 600 \$ chacun — un montant délibérément choisi juste sous un seuil de déclaration réglementaire de 10 000 \$ (le « saupoudrage » décrit par le cours). Le système RegTech de détection d'anomalies de la banque signale, indépendamment d'un dépôt à l'autre, chaque transaction structurée de cette manière avec une probabilité p . Si au moins une transaction est signalée, l'ensemble de l'opération est considéré comme détecté : le blanchisseur perd alors la totalité des 480 000 \$ par confiscation, et s'expose à une amende pénale fixe de 50 000 \$. S'il n'est jamais détecté, il perçoit une commission de 8 % du montant placé pour son propre compte.

- (a) Calculer le nombre de transactions nécessaires pour placer la totalité des 480 000 \$ par dépôts de 9 600 \$.
- (b) En prenant $p = 2\%$ pour chaque transaction prise isolément, calculer la probabilité qu'aucune des transactions ne soit jamais signalée sur l'ensemble de l'opération, puis la probabilité cumulée qu'au moins une le soit. Calculer le rapport entre cette probabilité cumulée et la probabilité p d'une transaction isolée : de combien de fois le fractionnement en de multiples petites transactions multiplie-t-il, au total, le risque de détection par rapport au risque encouru par une transaction unique ?
- (c) Calculer la perte totale du blanchisseur en cas de détection (confiscation plus amende), le gain en cas de succès (commission), puis l'espérance de gain de l'opération — probabilité de succès multipliée par le gain, moins probabilité de détection multipliée par la perte. Cette espérance est-elle positive ou négative ? Que devrait rationnellement décider un blanchisseur qui ne considérerait que ce seul calcul ?
- (d) La banque envisage de renforcer son système RegTech, ce qui porterait p de 2 % à 5 % par transaction. Recalculer la probabilité cumulée de détection et l'espérance de gain de l'opération à ce nouveau niveau de p . Déterminer ensuite, par le calcul, la valeur de p à laquelle l'espérance de gain de l'opération devient exactement nulle (le seuil d'indifférence du blanchisseur). Commenter l'ordre de grandeur de ce seuil : que révèle-t-il sur l'efficacité, même à un niveau de détection très faible par transaction, du dispositif RegTech décrit par le cours pour rendre le saupoudrage irrationnel à cette échelle de montant ?